

Privacy-enhancing technologies (PET) are technologies that embody fundamental data protection principles by minimizing personal data use, maximizing data security, and empowering individuals. PETs allow online users to protect the privacy of their personally identifiable information (PII), which is often provided to and handled by services or applications. PETs use techniques to minimize an information system's possession of personal data without losing functionality. Generally speaking, PETs can be categorized as either hard or soft privacy technologies.

Goals

The objective of PETs is to protect personal data and assure technology users of two key privacy points: their own information is kept confidential, and management of data protection is a priority to the organizations who hold responsibility for any PII. PETs allow users to take one or more of the following actions related to personal data that is sent to and used by online service providers, merchants or other users (this control is known as self-determination). PETs aim to minimize personal data collected and used by service providers and merchants, use pseudonyms or anonymous data credentials to provide anonymity, and strive to achieve informed consent about giving personal data to online service providers and merchants.

In privacy negotiations, consumers and service providers establish, maintain, and refine privacy policies as individualized agreements through the ongoing choice among service alternatives, therefore providing the possibility to negotiate the terms and conditions of giving personal data to online service providers and merchants (data handling/privacy policy negotiation). Within private negotiations, the transaction partners may additionally bundle the personal information collection and processing schemes with monetary or non-monetary rewards.

PETs provide the possibility to remotely audit the enforcement of these terms and conditions

at the online service providers and merchants (assurance), allow users to log, archive and look up past transfers of their personal data, including what data has been transferred, when, to whom and under what conditions, and facilitate the use of their legal rights of data inspection, correction and deletion. PETs also provide the opportunity for consumers or people who want privacy-protection to hide their personal identities. The process involves masking one's personal information and replacing that information with pseudo-data or an anonymous identity.

Families

Privacy-enhancing technologies can be distinguished based on their assumptions.

Soft privacy technologies

Soft privacy technologies are used where it can be assumed that a third-party can be trusted for the processing of data. This model is based on compliance, consent, control and auditing. Example technologies are access control, differential privacy, and tunnel encryption (SSL/TLS). An example of soft privacy technologies is increased transparency and access. Transparency involves granting people with sufficient details about the rationale used in automated decision-making processes. Additionally, the effort to grant users access is considered soft privacy technology. Individuals are usually unaware of their right of access or they face difficulties in access, such as a lack of a clear automated process.

Hard privacy technologies

With hard privacy technologies, no single entity can violate the privacy of the user. The assumption here is that third-parties cannot be trusted. Data protection goals include data minimization and the reduction of trust in third-parties.

Examples of such technologies include onion routing, the secret ballot, and VPNs used for

democratic elections.

Existing PETs

PETs have evolved since their first appearance in the 1980s. At intervals, review articles have been published on the state of privacy technology:

A principal, though fundamentally theoretical, overview of terminology and principal anonymization technology is found in Pfitzmann & Hansen's terminology of anonymity.

In 1997, a report by Goldberg, Wagner and Brewer at the University of California, Berkeley summarized PETs.

In 2003, Borking, Blarkom and Olk reviewed the technologies from a data protection perspective in their Handbook of privacy enhancing technologies.

In 2007, Fritsch published an historic, taxonomic and practical overview of contemporary privacy-enhancing technology for the Internet for the research project PETWeb.

In 2008, Fritsch and Abie documented the gap between implemented PETs and their successful deployment in a research roadmap for PETs.

In 2015, Heurix et al. published a taxonomy of privacy enhancing technologies.

A specialization of PET research that looks into increasing the transparency of data processing is called transparency-enhancing technologies (TETs). A review article by Janic et al. summarizes developments in TETs. Murmann and Fischer-Hübner published a review of transparency tools in 2017.

In 2019, the World Economic Forum published a white paper exploring PET use cases in financial technology and infrastructure.

The Boston Women's Workforce Council published reports in 2017 and 2019 exploring the gender pay gap in a number of Boston-based companies. The data was compared using PETs, to ensure that sensitive employee information remained private throughout.

In 2021, the European Data Protection Board, which oversees the enforcement of GDPR, and the European Union Agency for Cybersecurity published technical guidance supporting Secure Multi-Party Computation as a valid privacy-preserving safeguard, applying to both healthcare and cybersecurity use cases.

Examples

Examples of existing privacy enhancing technologies are:

General PET building blocks:

Obfuscation refers to the many practices of adding distracting or misleading data to a log or profile, which may be especially useful for frustrating precision analytics after data has already been lost or disclosed. Its effectiveness against humans is questioned, but it has greater promise against shallow algorithms. Obfuscating also hides personal information or sensitive data through computer algorithms and masking techniques. This technique can also involve adding misleading or distracting data or information so it is harder for an attacker to obtain the needed data.

Providing users with access to their personal data: Here, a user gains control over the privacy of their data within a service because the service provider's infrastructure allows users to inspect, correct or delete all their data that is stored at the service provider.

Pseudonymization is a data management technique that replaces an individual's identity or personal information with an artificial identifiers known as Pseudonyms. This de-identification method enables contents and fields of information to be covered up so as to deter attacks and hackers from obtaining important information. These Pseudonyms can be either placed in groups or for individual pieces of information. Overall, they serve to discourage information stealing while also maintaining data integrity and data analysis.

PETs for Privacy-Preserving Communication:

Communication anonymizers hiding a user's real online identity (email address, IP address, etc.) and replacing it with a non-traceable identity (disposable / one-time email address, random IP address of hosts participating in an anonymising network, pseudonym, etc.). They can be applied to everyday applications like email, Web browsing, P2P networking, VoIP, Chat, instant messaging, etc.

Shared bogus online accounts: This technology de-links an online account from a specific user's habits by allowing many users to share the account, and setting up fake personal information in the account settings. To accomplish this, one person creates an account for a website like MSN, providing bogus data for their name, address, phone number, preferences, life situation etc. They then publish their user-IDs and passwords on the internet. Everybody can now use this account comfortably. Thereby the user is sure that there is no personal data in the account profile (and is freed from the hassle of having to register at the site).

PETs for Privacy-Preserving Data Processing are PETs that facilitate data processing or the production of statistics while preserving privacy of the individuals providing raw data, or of the specific raw data elements. Some examples include:

Enhanced privacy ID (EPID) is a digital signature algorithm supporting anonymity. Unlike traditional digital signature algorithms (e.g., PKI), in which each entity has a unique public verification key and a unique private signature key, EPID provides a common group public verification key associated with many of unique private signature keys. EPID was created so that a device could prove to an external party what kind of device it is (and optionally what software is running on the device) without needing to also reveal exact identity, i.e., to prove you are an authentic member of a group without revealing which member. It has been in use since 2008.

Zero-knowledge proof is a method by which one party (the prover) can prove to another party

(the verifier) that they know a value x , without conveying any information apart from the fact that they know the value x .

Ring signature is a type of digital signature that can be performed by any member of a set of users that each have a pair of cryptographic keys.

Format-preserving encryption (FPE), refers to encrypting in such a way that the output (the ciphertext) is in the same format as the input (the plaintext)

Blinding is a cryptography technique by which an agent can provide a service to a client in an encoded form without knowing either the real input or the real output.

PETs for Privacy Preserving Data Analytics are a subset of the PETs used for data processing that are specifically designed for the publishing of statistical data. Some examples include:

Homomorphic encryption is a form of encryption that allows computation on ciphertexts.

Secure multi-party computation is a method for parties to jointly compute a function over their inputs while keeping those inputs private.

Non-interactive zero-knowledge proof (NIZKs) are zero-knowledge proofs that require no interaction between the prover and verifier.

Differential privacy: An algorithm is constrained so that the results or outputs of a data analysis cannot tell if a certain individuals' information is being used to analyze and form the results. This technique focuses on large databases and hides the identity of individual "inputs" who might have private data and privacy concerns,

Federated learning is a machine learning technique that trains models across multiple distributed nodes. Each node houses a local, private dataset.

Adversarial stylometry methods may allow authors writing anonymously or pseudonymously to resist having their texts linked to their other identities due to linguistic clues.

Future

Examples of privacy-enhancing technologies that are being researched or developed include limited disclosure technology, anonymous credentials, negotiation and enforcement of data handling conditions, and data transaction logs.

Limited disclosure technology provides a way of protecting individuals' privacy by allowing them to share only enough personal information with service providers to complete an interaction or transaction. This technology is also designed to limit tracking and correlation of users' interactions with these third parties. Limited disclosure uses cryptographic techniques and allows users to retrieve data that is vetted by a provider, to transmit that data to a relying party, and have these relying parties trust the authenticity and integrity of the data.

Anonymous credentials are asserted properties or rights of the credential holder that do not reveal the true identity of the holder; the only information revealed is what the holder of the credential is willing to disclose. The assertion can be issued by the user, by the provider of the online service or by a third party (another service provider, a government agency, etc.). For example:

Online car rental agencies does not need to know the true identity of the customer. It only needs to make sure that the customer is over 23 (as an example), that the customer has a drivers license, health insurance (i.e. for accidents, etc.), and that the customer is paying. Thus there is no real need to know the customers name nor their address or any other personal information. Anonymous credentials allow both parties to be comfortable: they allow the customer to only reveal so much data which the car rental agency needs for providing its service (data minimization), and they allow the car rental agency to verify their requirements and get their money. When ordering a car online, the user, instead of providing the classical name, address and credit card number, provides the following credentials, all issued to pseudonyms (i.e. not to the real name of the customer):

An assertion of minimal age, issued by the state, proving that the holder is older than 23

(note: the actual age is not provided)

A driving licence, i.e. an assertion, issued by the motor vehicle control agency, that the holder is entitled to drive cars

A proof of insurance, issued by the health insurance

Digital cash

Negotiation and enforcement of data handling conditions. Before ordering a product or service online, the user and the online service provider or merchant negotiate the type of personal data that is to be transferred to the service provider. This includes the conditions that shall apply to the handling of the personal data, such as whether or not it may be sent to third parties (profile selling) and under what conditions (e.g. only while informing the user), or at what time in the future it shall be deleted (if at all). After the transfer of personal data took place, the agreed upon data handling conditions are technically enforced by the infrastructure of the service provider, which is capable of managing and processing and data handling obligations. Moreover, this enforcement can be remotely audited by the user, for example by verifying chains of certification based on trusted computing modules or by verifying privacy seals/labels that were issued by third party auditing organizations (e.g. data protection agencies). Thus instead of the user having to rely on the mere promises of service providers not to abuse personal data, users will be more confident about the service provider adhering to the negotiated data handling conditions.

Lastly, the data transaction log allows users the ability to log the personal data they send to service provider(s), the time in which they do it, and under what conditions. These logs are stored and allow users to determine what data they have sent to whom, or they can establish the type of data that is in possession by a specific service provider. This leads to more transparency, which is a pre-requisite of being in control.

See also

Code as speech

Crypto-shredding

Cypherpunk

Digital credentials

Digital self-determination

Enhanced privacy ID (EPID)

Identity management

Information privacy

Information processing

Information security

List of security-focused operating systems

Privacy

Privacy by design

Privacy Engineering

Privacy-enhanced Electronic Mail

Privacy software

Privacy policy

Self-sovereign identity

References

van Blarckom, G.W.; Borking, J.J.; Olk, J.G.E. (2003). "PET". Handbook of Privacy and Privacy-Enhancing Technologies. (The Case of Intelligent Software Agents). ISBN 978-90-74087-33-9.

Cánovas Sanchez, Jose Luis; Bernal Bernabe, Jorge; Skarmeta, Antonio (2018). "Integration of Anonymous Credential Systems in IoT Constrained Environments". IEEE Access. 6: 4767–4778. Bibcode:2018IEEEA...6.4767S. doi:10.1109/ACCESS.2017.2788464.

Notes

External links

PETs in general:

The EU PRIME research project (2004 to 2008) aiming at studying and developing novel PETs

About PETs from the Center for Democracy and Technology

Annual symposium on PETs

Report about PETs from the META Group, published by the Danish ministry of science

Activities of the EU Commission in the area of PETs [broken link](#)

Anonymous credentials:

IBM Zürich Research Lab's idemix

Stefan Brands' U-Prove Digital credential 'credentica'

which is now owned by Microsoft U-Prove

Privacy policy negotiation:

The W3C's P3P

IBM's EPAL

Sören Preibusch: Implementing Privacy Negotiations in E-Commerce, Discussion Papers of
DIW Berlin 526, 2005